

Data Security and Acceptable Use Policy

=====

Purpose

This policy sets the minimum expectations for handling Northwind Robotics' information, systems, and devices. It protects company data, customer information, employee information, and internal business records from unauthorized access, loss, and misuse. It applies to every employee, contractor, and intern, on any device used for company work, in the office or remotely.

General Principles

Company systems and data are for legitimate work only. Employees must:

- protect their credentials and use approved authentication methods,
- keep company devices patched and configured to company standards,
- use only approved software, communication channels, and storage,
- treat company information as sensitive even when it is not labeled,
- report suspected security problems immediately.

Authentication and Multi-Factor Authentication

Multi-factor authentication (MFA) is mandatory on all company systems that support it.

Employees must:

- use the company single sign-on and a company-approved authenticator or hardware key,
- use a company-approved password manager and never reuse a work password on a personal account,
- never share a password, one-time code, or push-approval with anyone, including IT,
- approve an MFA prompt only when they personally initiated the sign-in.

If a credential, device, or hardware key is lost or an employee approves an MFA prompt they did not initiate, they must report it to the security team within one hour.

Device Standards

Company work involving Internal, Confidential, or Restricted information (see the Information Classification Standard) must be done on a company-managed device. Company-managed devices must have:

- full-disk encryption enabled,

- automatic screen lock after no more than 10 minutes of inactivity,
- the company endpoint agent and current operating system updates,
- only software approved by IT.

Employees must not install unapproved software, browser extensions, or remote-access tools on a company-managed device, and must not disable security controls. Personal devices may be used only for low-sensitivity tasks explicitly allowed by IT (for example, calendar and MFA), never for storing or downloading company data.

Network Use

Employees should use a trusted network and the company VPN when handling non-public information. Public or untrusted Wi-Fi (airports, hotels, cafes) may be used only with the VPN active. Home networks used for work should have a unique administrator password and current router firmware.

Acceptable Use

Company systems may be used for reasonable, incidental personal purposes that do not interfere with work, consume significant resources, or create risk. The following are prohibited:

- storing or moving company data into personal email, personal cloud storage, or unapproved file-sharing tools,
- attempting to bypass security controls or access data beyond the employee's role,
- using company systems for harassment, discrimination, or unlawful activity,
- viewing, creating, or distributing content that would violate the Code of Conduct,
- installing or running unapproved software or connecting unapproved hardware,
- using company systems to run a personal business or for significant non-work activity.

Confidentiality and Least Privilege

Confidential information includes business plans, customer data, employee records, financial information, source code, and anything with a confidentiality designation or a reasonable expectation of privacy. Employees access only what their role requires, share it only with people who need it, and use approved systems to do so. Access is granted for business need and is removed when the need ends or when misuse occurs. Curiosity is not a business need.

Data Handling and Storage

Company data lives in approved, company-managed repositories with the correct access controls and retention settings. Do not copy company data to local personal storage or removable media unless IT has approved it for a specific business purpose. External sharing uses the approved process, with the correct permissions and any required approval from the data owner. Follow the

Information Classification Standard for labeling, sharing, and destruction.

Email, Messaging, and Phishing

Employees should be cautious with unexpected links and attachments and should report suspected phishing using the report button or to the security team. Do not enter company credentials into a site reached from an email link. The company runs phishing simulations; repeated failures result in additional training.

Reporting Security Issues

Any suspected compromise, data exposure, lost or stolen device, phishing event, or unusual system access must be reported to the security team within one hour and to the employee's manager. Do not try to investigate or "fix" a suspected breach yourself in a way that could destroy evidence. Early reporting reduces harm; the company does not penalize good-faith reports of the reporter's own mistakes.

Offboarding and Role Changes

When an employee leaves or changes roles, access is adjusted or removed, and company devices and data must be returned or transferred through IT. Employees must not retain company data after employment ends.

Consequences

Violations may result in additional training, removal or restriction of access, corrective action, or termination of employment, depending on the seriousness and circumstances. Intentional data theft or sabotage is treated as grounds for immediate termination and possible legal referral.

Related Policies

- Information Classification Standard
- Remote and Hybrid Work Policy
- Out-of-State and International Remote Work Policy
- Onboarding and Equipment Provisioning Policy
- Workplace Conduct and Grievance Procedure

Summary

Use company-managed devices with encryption, MFA, a password manager, and a 10-minute screen lock. Keep company data in approved systems, never in personal cloud or email. Use the VPN on untrusted networks. Access only what your role needs. Report a lost device, a phishing hit, or any suspected incident to the security team within one hour.

